

THE SCHOOL OF MATHEMATICS



THE UNIVERSITY
of EDINBURGH

Detecting Malicious Insider Emails via Metadata and Semantic Deviations from Historical Baselines

by

Jackson Cramer, s2274544

August 2026

Supervised by
Dr. Sjoerd Beentjes and Dr. Gordon Ross

Executive Summary

Malicious insiders, a term used to describe members of an organisation who abuse their authorised access to cause harm, make detection challenging as these users operate within their allowed boundaries. A key measure for detecting malicious activity is an anomaly score, which quantifies how far a user’s behaviour deviates from an established baseline of normal activity. Our goal is to calculate an anomaly score in order to detect malicious acts, specifically via email, before they escalate.

To achieve this, we fit a series of anomaly-detection models to approximately 66,000 emails across 63 users from a synthetic dataset. These models score each email using both metadata and semantic embeddings to capture deviations from historical behaviour, with three baselines of varying specificity constructed under each model to evaluate tradeoffs across varying data recency.

Using these models, we found that an ensemble combining two anomaly-detection methods, both of which utilise multivariate relationships between email characteristics, identified substantially more malicious emails than simpler alternatives, especially at stricter cut-offs. We also found that no single historical baseline performed best across all models, but that the global baseline, built from the whole organisation’s activity instead of each user’s own history, produced the most reliable results overall. We also found that the semantic content of an email proved informative even though models relied mainly on correlated features, with malicious emails showing consistently higher semantic deviation than legitimate ones. Additionally, whether an email was addressed outside the organisation was the most important predictor of malicious activity, as instances in which a user sends sensitive data outside the organisation makes up our dataset’s primary malicious scenario.

We therefore recommend the use of an ensemble of anomaly-detection models that captures the multivariate relationships between email characteristics, fitted under a global baseline, to detect malicious insiders who move data out of the organisation by email. However, since no single baseline performed best across all models, baseline choice should be treated as a modelling decision made alongside model selection, rather than fixed in advance.

Contents

1	Introduction	3
2	Materials and Methods	3
2.1	Data Overview	3
2.2	Historical Baseline Specification	3
2.3	Semantic Embedding and Deviation	4
2.4	Anomaly Scoring Models	4
2.4.1	Z-Score	4
2.4.2	PCA Reconstruction Error	4
2.4.3	Isolation Forest	5
2.4.4	Ensemble	5
2.4.5	Model-Specific Baseline Deviations	5
3	Results	5
3.1	Model Comparison	5
3.1.1	Ensemble Weight Selection	5
3.1.2	Precision and Recall by Baseline and Detection Model	6
3.2	Model Diagnostics	7
3.2.1	Baseline Fallback Analysis	7
3.2.2	Anomaly Scores vs. Observed Maliciousness	7
3.2.3	Feature Relationships and Importance	9
3.2.4	Scenario Analysis	10
3.2.5	Score Separation and Evaluation Uncertainty	10
4	Discussion	11
4.1	Limitations	11
4.2	Conclusion	11
	Appendices	13
A	Dataset Variable Definitions	13
B	Insider Threat Scenarios	13
C	Baseline Tier Labels	13
D	Per-Fold Recall	14

1 Introduction

Malicious insiders are trusted partners or employees of an organisation who abuse their authorised access to an organisation by committing malicious acts such as fraud, sabotage, and theft of intellectual property [1]. With growing reliance on digital communication, many insider acts are committed digitally by email, increasing pressure for organisations to detect these threats before damage occurs. A key challenge is that insiders act within their authorised access, making their behaviour difficult to distinguish from legitimate activity. Being able to accurately model what constitutes "normal" behaviour for a given user allows an organisation to flag anomalies in real time, allowing them to respond to threats before they escalate.

Historically, insider threat detection has relied on two general approaches: misuse-based detection, which models known malicious behaviours and flags new activity that matches them, and anomaly-based detection, which builds a baseline profile of legitimate behaviour and scores new activity by its deviation from that baseline [2]. Misuse-based systems can only catch insider activity that matches a previously known malicious pattern or rule, leaving unseen strategies undetected. This project therefore adopts an anomaly-based approach.

However, the challenge with this approach is deciding what constitutes an appropriate baseline. A baseline that is too narrow may fail to capture a user's genuine variability, while a baseline built over too long a window may absorb a gradual shift towards malicious behaviour into the norm.

In this project, we detect malicious insider behaviour using synthetic email data from the CERT Insider Threat Test Dataset [3]. While most existing work on this dataset aggregates a user's activity to daily summaries [4], we score each email individually, representing it through both metadata and semantic embeddings of its content. We compare four commonly used anomaly-detection methods under window, expanding, and global baselines, allowing us to isolate the trade-offs of each baseline independent of the detection method used, and assess whether more sophisticated, multivariate detectors capture anomalies that a simple univariate baseline may miss.

2 Materials and Methods

2.1 Data Overview

Email data spanning from January 2010 to May 2011 were obtained from the CERT Insider Threat Test Dataset (r6.2), a collection of synthetic insider threat datasets generated by Carnegie Mellon University's CERT Division [3]. Of this collection, we utilise the email dataset, comprising over 10,000,000 sent and viewed messages across 4,000 users. This dataset contains both metadata and seman-

tic information, which respectively represent information about the email (e.g. date, attachments) and the text of its message.

Data preprocessing began by engineering multiple features thought to be indicative of a malicious email, each defined in Appendix A. Because only one of the 99 malicious emails consisted of a "View" without a corresponding "Send", we restrict our analysis to "Send" emails, ensuring all scored emails represent the same activity type and are directly comparable.

We then accessed the r6.2 LDAP files, which describe each employee's role within the organisation. Using each user's department in a given month and year, we joined department onto our emails dataset for use in baseline construction.

Finally, malicious emails were labelled by matching the unique email identifier extracted from each recorded "Send" event against the r6.2 answer files (r6.2-2, r6.2-3, r6.2-4), each corresponding to a scenario defined in Appendix B.

2.2 Historical Baseline Specification

Our model assigns each email an anomaly score that quantifies how far it deviates from the sender's previous emails. Which previous emails are included is what we will denote as our baseline, and evaluating the trade-offs between each is a key objective of our study. Each baseline is visualised in Figure 1 below.

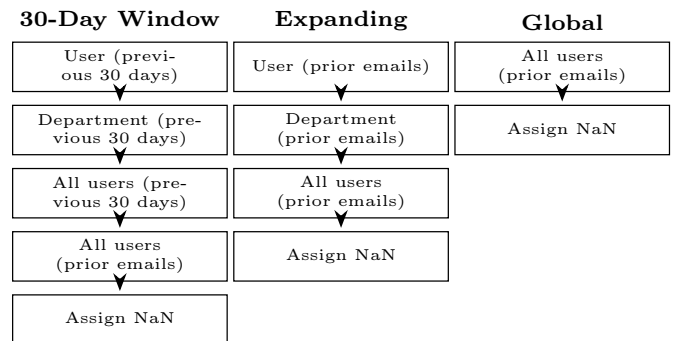


Figure 1: Fallback hierarchy of baseline specifications. At each tier, if fewer than 40 baseline emails are available, move down to the next tier.

The **30-day window** baseline scores each email against the sender's emails from the previous 30 days, capturing the sender's recent behaviour across a full monthly work cycle so that recurring month-end activity is treated as normal. The trade-off is sensitivity to low activity, as users that send few emails may lack sufficient recent history.

The **expanding** baseline removes the time restriction and scores against all of a user's prior emails, capturing the full range of behaviour at the cost of not absorbing legitimate changes in role or writing style, which may continue

to be scored as anomalous.

The **global** baseline scores each email against all prior emails, regardless of user, capturing normality across the organisation. Its trade-off is that role-driven variation between users is treated as anomalous, while a malicious email that is unusual for its sender but normal across the organisation may be missed.

At each tier, if less than 40 baseline emails are available, the baseline moves down to the next wider tier (see Figure 1). This threshold was chosen to ensure enough reference emails are available for stable estimates that are not dominated by individual messages, while also ensuring every malicious email is scored, as the malicious email with the fewest prior emails has 48 available. Evaluation of these specifications is presented in Section 3.2.1.

Lastly, though all emails are scored, malicious emails are excluded from each baseline pool so that every email is scored against non-malicious behaviour, following the standard semi-supervised method of anomaly detection [5].

2.3 Semantic Embedding and Deviation

To incorporate email content into our anomaly-scoring model, each email must first be converted from text into a numerical representation. While traditional, count-based methods such as *Bag-of-Words* represent documents using word frequencies, they ignore word order and contextual meaning [6]. We therefore use the transformer-based **all-MiniLM-L6-v2** model from the Python **sentence-transformers** package, which maps each email to a dense 384-dimensional embedding, such that emails with similar contextual meaning lie close together even when they share few words [7].

For efficiency, we randomly select 50 users without any malicious emails in their history, and combine their data with that of each of the 13 total users with malicious emails. This results in a total of 63 users across $\approx 66,000$ unique emails, each of which we embed the content of using the **all-MiniLM-L6-v2** model.

Using these embeddings, we quantify how far the content of each email is from the user’s baseline emails, under each baseline defined in Section 2.2. For email i with unit-normalised embedding $\hat{\mathbf{x}}_i$ and normalised mean embedding of the baseline $\hat{\boldsymbol{\mu}}$, we define the cosine distance

$$d_i = 1 - \hat{\mathbf{x}}_i^\top \hat{\boldsymbol{\mu}}, \quad (1)$$

which we then standardise against the sample mean $\bar{d}$ and standard deviation s_d of the baseline emails’ distances to that centroid, giving

$$z_i = \frac{d_i - \bar{d}}{\max(s_d, 0.02)}. \quad (2)$$

This standardisation makes scores comparable across users

and baselines, while the floor at 0.02 prevents a homogeneous baseline from producing arbitrarily large scores.

2.4 Anomaly Scoring Models

The goal of this report is to assign each email an anomaly score reflecting its deviation from past email behaviour, with higher scores indicating a greater likelihood of malicious activity. Using each of the three baselines defined in Section 2.2, along with the features listed in Appendix A, we explore four approaches to assigning this score. We note that before scoring under any model, each feature is standardised against the non-malicious baseline emails, consistent with our semi-supervised approach mentioned in Section 2.2.

2.4.1 Z-Score

Our baseline detector is the univariate z -score. For each email i and feature j we calculate the sample mean $\bar{x}_j$ and standard deviation s_j of that feature over i ’s baseline emails, and compute

$$z_{ij} = \frac{x_{ij} - \bar{x}_j}{\max(s_j, \phi_j)}, \quad (3)$$

where ϕ_j is a floor set at 5% of the feature’s standard deviation over all emails before i , preventing a homogeneous baseline from inflating the score.

Because deviations are asymmetric for some features, we make scores directional. For message size, attachment count, and recipient count, z_{ij} is rounded up to zero if it is negative so only unusually high values are anomalous, while remaining metadata features are scored two-sided as $|z_{ij}|$. Our standardised semantic deviation feature is also rounded up to zero if negative, as an email closer than usual to a user’s centroid is not anomalous. The final score is the mean of these per-feature scores.

Every score decomposes into per-feature contributions, giving flagged emails accessible explanations. However, the unweighted average dilutes a large deviation in one feature with the rest, so an email truly malicious in one characteristic may score too low to be flagged.

2.4.2 PCA Reconstruction Error

Our second method is PCA reconstruction error (hereafter PCA), which projects each email onto the low-dimensional subspace capturing most of the variation in normal behaviour and measures the residual between the email and its reconstruction, where normal emails are well described by that subspace and anomalous emails produce a larger residual [8].

For a given email, we fit PCA to its baseline emails, retaining the smallest number of components explaining at least 80% of the variance, which keeps the main structure of normal behaviour while discarding noise [9]. This yields five components under all baselines.

For email i with standardised feature vector $\mathbf{x}_i$ and reconstruction $\tilde{\mathbf{x}}_i$, obtained by projecting onto the five retained components and mapping back, we compute the squared residual

$$e_i = \|\mathbf{x}_i - \tilde{\mathbf{x}}_i\|^2. \quad (4)$$

For efficiency, the model is refitted every 50 emails for the window/expanding baselines and after 25% growth for the global baseline, as a fixed interval would require many refits for negligible change. Since each model is fitted only on emails preceding its refit point, this reuse cannot introduce leakage, which is the use of information unavailable at the time an email would have been scored.

Unlike z -score, this method scores an email’s joint structure, so it can identify an email whose individual features appear normal but whose combination is not. However, PCA captures only linear correlation, so a user with two different email patterns, such as messages to a colleague vs. bulk reports to the team, is flattened into one subspace, so an email lying between them reconstructs well despite never having occurred.

2.4.3 Isolation Forest

Our next method, the isolation forest, recursively partitions the feature space using random splits on randomly chosen features, with each split point drawn uniformly between the feature’s minimum and maximum among the emails at that node. Emails that differ from the rest are isolated after few splits, while normal emails lie deeper in the tree. We fit a forest of 100 trees to each email’s baseline to ensure path length convergence [10]. For email i with standardised feature vector $\mathbf{x}_i$, we average the path length $h(\mathbf{x}_i)$, which is the number of splits required to isolate the email, across the ensemble and normalise by $c(n)$, the expected path length of an unsuccessful search in a binary tree of n emails, giving

$$s(\mathbf{x}_i, n) = 2^{-\frac{E[h(\mathbf{x}_i)]}{c(n)}}, \quad (5)$$

A short average path length therefore indicates an anomaly [10]. For efficiency, we refit every 250 emails for the per-user baseline and after 25% growth for the global baseline. Compared to PCA, we specify a larger interval of 250 because of the greater cost of fitting an ensemble of trees.

Unlike PCA, isolation forest can represent normal behaviour as distinct regions instead of a single linear hyperplane. The middle-ground email from Section 2.4.2 now falls in a sparsely populated region and is isolated after few splits, correctly being flagged. However, each split looks at one feature at a time, so relationships between features are only captured indirectly.

2.4.4 Ensemble

Our final model, the ensemble, balances the trade-offs of each detector by combining the three scores via grid search under K -fold cross-validation. The grid is built from combinations of weights $[0, 0.5, 1.0, 1.5]$, normalised to sum to one, producing 49 distinct ensembles. The ensemble scores are converted to percentile ranks before taking a weighted sum, preventing the ensemble from being dominated by whichever method produces the largest raw values.

To select weights, we first partition our 13 malicious users into five folds, chosen to balance fold size with our limited number of malicious users. We then assign each malicious email to its sender’s fold, so weights tuned on one set of users are only evaluated on users unseen during selection, preventing leakage.

Within each fold, percentile ranks are recomputed at each stage, removing the held-out users’ malicious emails when tuning and the training users’ malicious emails when evaluating, so neither set influences the other’s rankings.

Weights are selected by maximising recall, the proportion of malicious emails correctly flagged, at a specific cut-off, including 1%, 5% and 10%, reflecting the volumes an analyst may plausibly review. Each run selects the weighting with the highest mean recall across cut-offs, then evaluates it on the held-out users at all three cut-offs, recording mean recall across each fold. Our final ensemble is the weighting chosen most often across the runs, favouring weights that succeed consistently instead of in a single run.

2.4.5 Model-Specific Baseline Deviations

The assignment of NaN scores varies slightly by model. The z -score averages across features, so an email with a missing semantic deviation is scored NaN instead of averaging over an inconsistent number of features. PCA and isolation forest require complete feature vectors both for the scored email and for its baseline, so these are also scored NaN when less than 40 complete baseline emails remain. The fallback tier reached is therefore labelled explicitly for each email, defined in Appendix C and evaluated in Section 3.2.1.

3 Results

3.1 Model Comparison

3.1.1 Ensemble Weight Selection

Only 98 of our $\approx 66,000$ scoreable emails are malicious, so recall is compared against what flagging the same proportion at random would achieve, given in the final row of Table 1. Because prior work on this dataset evaluates at the user-day level [4], no published per-email recall is available, so we additionally use the univariate z -score as

a baseline reference.

Table 1: Held-out recall (%) by tuning and evaluation cut-off. Each row gives the modal weighting selected across the five folds when tuned at that cut-off, then evaluated at all three, reported as the mean $\pm$ standard deviation across folds. Weights (w_z, w_{PCA}, w_{iF}) correspond to the z -score, PCA, and isolation forest models respectively. The final row is the recall expected from flagging the same proportion of emails at random.

Tuned at	Weights (w_z, w_{PCA}, w_{iF})	Recall, evaluated at		
		1%	5%	10%
1%	(0, .75, .25)	1.70 $\pm$ 3.80	33.12 $\pm$ 17.06	49.78 $\pm$ 28.69
5%	(.2, .6, .2)	5.10 $\pm$ 8.19	35.94 $\pm$ 17.49	52.50 $\pm$ 31.89
10%	(0, .75, .25)	2.92 $\pm$ 6.53	33.78 $\pm$ 18.01	51.38 $\pm$ 30.46
Random	—	1.0	5.0	10.0

As shown in Table 1, the ensemble improves substantially on random flagging at the 5% and 10% cut-offs across all three tuning cut-offs, but not at 1%, where the standard deviations are as large as the means, indicating that no weighting detects reliably at this granularity. Recall is near-identical down each evaluation column, indicating performance is insensitive to the tuning cut-off.

The presented modal weightings were chosen in four of the five folds at each cut-off, indicating that weight selection is stable. Performance, however, varies substantially between folds, with per-fold recall at the 10% cut-off ranging from $\approx 8\%$ to $\approx 81\%$, with fold 3 accounting for both the highest value and the only non-zero recall at 1% (see Appendix D). Therefore, with our only two or three held-out users per fold, a single user can move the average, so the mean recalls in Table 1 should be read as indicative, not precise.

The weighting (0, 0.75, 0.25) was selected at two of the three tuning cut-offs, and the third differed only slightly, so we adopt it as our final ensemble. The z -score therefore contributes nothing, PCA dominates, and the isolation forest makes a smaller but meaningful contribution. These results indicate that our multivariate approaches outperform the univariate z -score baseline, examined directly in Section 3.1.2.

3.1.2 Precision and Recall by Baseline and Detection Model

Having scored every email under each of the four detection methods and three baselines, we now evaluate recall at the 1%, 5%, and 10% cut-offs (see Table 2).

Table 2: Recall (%) at each cut-off, by detection method and baseline. The final row is the recall expected from flagging the same proportion of emails at random.

Method	Baseline	1%	5%	10%
z -score	Window	3.06	11.22	21.43
	Expanding	4.08	9.18	25.51
	Global	4.08	18.37	32.65
PCA	Window	2.04	32.65	60.20
	Expanding	10.20	57.14	75.51
	Global	17.35	52.04	66.33
Isolation Forest	Window	1.02	10.20	23.47
	Expanding	3.06	8.16	22.45
	Global	4.08	35.71	64.29
Ensemble	Window	3.06	38.78	71.43
	Expanding	6.12	56.12	80.61
	Global	35.71	57.14	82.65
Random	—	1.0	5.0	10.0

We first note that the ensemble results here are not equal to those of Table 1, nor are they expected to be. Table 1 reports recall on held-out users, averaged across folds, while Table 2 applies the final weights selected in Section 3.1.1 to all scored emails, therefore representing in-sample performance, as every malicious user contributed to the weight selection.

Across nearly all methods, baselines, and cut-offs, recall exceeds that expected from random flagging, with the margin widening as the cut-off grows. The exceptions occur only at 1%, where too few malicious emails rank highly enough to fall within such a small flagged set.

Additionally, no single baseline is best for every detector, supporting our exploration of multiple baselines. For example, global gives the highest recall for the z -score, isolation forest, and ensemble, while expanding does so for PCA.

Among the individual (non-ensemble) detectors, PCA achieves the highest recall in every case but the window at 1% cut-off, where the z -score exceeds it by $\approx 1\%$. The z -score and isolation forest perform similarly under the window and expanding baselines, but isolation forest is far stronger under global. The z -score is therefore the weakest detector overall, supporting the indication of Section 3.1.1 that multivariate scoring detects malicious emails better than univariate scoring of each feature in isolation.

The ensemble gives the highest recall at every baseline and cut-off except under expanding, where PCA is higher at 1% and 5%. The ensemble performs strongest under the global baseline, where it leads all three cut-offs and more than doubles the next-highest recall at 1%.

Recall quantifies how well our model finds malicious emails, but it does not show the cost of widening the cut-offs. This is done by precision, which tells us how many of the flagged emails are actually malicious, and therefore

how much an analyst has to look through to find them. Under the global ensemble, for example, moving from 1% to 10% raises recall from 35.71% to 82.65%, but reduces precision from 5.25% to 1.21%. Figure 2 visualises this trade-off.

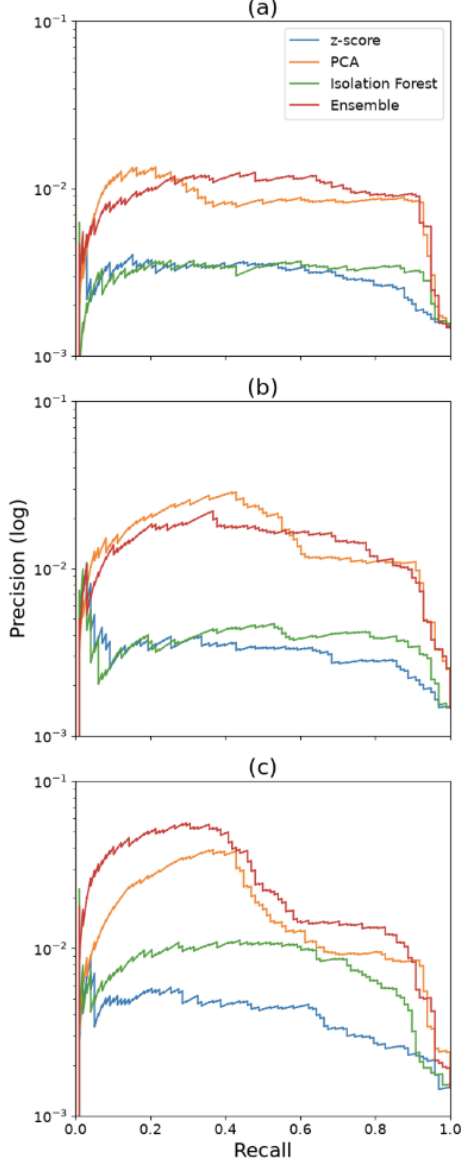


Figure 2: Precision-recall curves for each detection method under (a) the 30-day window, (b) expanding, and (c) global baselines, where each point corresponds to a different cut-off, with larger cut-offs appearing further right. Precision is shown on a log scale for ease of visualisation.

Across all three baselines, the PCA and ensemble curves sit above those of the z -score and isolation forest at nearly every recall value, indicating higher precision at any given level of detection.

Given that a detector is only useful if it ranks malicious emails highly, we focus on the left-hand portion of each curve, where precision is measured over the smallest,

highest-scoring flagged sets. Under the window baseline (Plot (a)), PCA achieves the highest precision at low recall, with the ensemble overtaking it thereafter. Under expanding (Plot (b)), PCA reconstruction error remains above the ensemble throughout, while under global (Plot (c)) the ensemble leads across the whole region. The global baseline also produces the highest curves for every detector, suggesting that scoring against all prior emails separates malicious from non-malicious more sharply than per-user history does.

We therefore select the ensemble model under the global baseline for subsequent diagnostics.

3.2 Model Diagnostics

3.2.1 Baseline Fallback Analysis

As discussed in Section 2.2, each baseline falls to the next tier when less than 40 baseline emails are available. Table 3 counts how many emails were scored at each tier.

Table 3: Tier counts across the three baselines. PCA and isolation forest (iF) use the same missing feature method, so each pair of counts is reported once. Totals are 66,743 per column.

Baseline	Tier	Z-Score	PCA / iF
Window	Personal	61,924	61,886
	Department	4,492	4,490
	Global (window)	287	287
	Missing features (NaN)	0	40
	Insufficient data (NaN)	40	40
Expanding	Personal	64,223	64,183
	Department	2,240	2,240
	Global (all prior)	240	240
	Missing features (NaN)	0	40
	Insufficient data (NaN)	40	40
Global	Global (all prior)	66,703	66,663
	Missing features (NaN)	0	40
	Insufficient data (NaN)	40	40

As shown, the top tier accounts for the vast majority of emails under every baseline, confirming sufficient personal history was available for most emails. Nonetheless, a non-trivial amount of observations still relied on these fallbacks, meaning the fallback structure activated meaningfully instead of serving only as a safeguard. NaN scores were rare (40 under z -score, 80 under PCA/iF), meaning our minimum baseline excludes a negligible fraction of emails. None of those excluded were malicious, so every malicious email received a score under every baseline.

3.2.2 Anomaly Scores vs. Observed Maliciousness

We now examine whether our selected global ensemble model’s anomaly scores reflect the actual patterns of malicious behaviour in each feature. We first compare each categorical feature’s observed distribution between mali-

cious and non-malicious emails against the corresponding ensemble score distribution (see Figure 3).

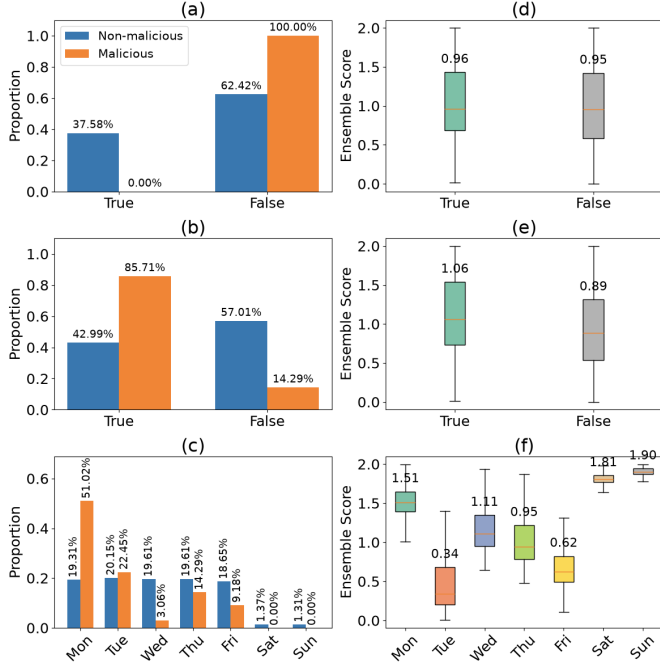


Figure 3: Observed proportions bar plots (a–c) and ensemble score box plots (d–f) by categorical feature, with proportions and medians annotated above, respectively. (a) External sender proportions, (b) external recipient proportions, (c) day-of-week proportions, (d) external sender ensemble scores, (e) external recipient ensemble scores, (f) day-of-week ensemble scores.

We first notice that no malicious emails were sent externally, yet ensemble scores are near-identical for internal and external senders (medians 0.95 vs 0.96). Since external senders are common in the non-malicious baseline, sending externally is not unusual and therefore does not raise an email’s score.

External recipient shows a clearer signal, with 85.71% of malicious emails going to an external recipient, versus 57.01% of non-malicious emails delivered internally, with ensemble scores following the same direction (median 1.06 vs 0.89). Because external recipients are a minority in the baseline, sending externally registers as a deviation indicative of malicious behaviour.

Day-of-week shows only a partial match, such that malicious emails cluster on Monday (51.02% vs 19.31% non-malicious) and Monday scores are high, but the correspondence breaks down elsewhere. Our model measures based on deviation from a sender’s baseline, so a high score is made when emails are unusual, not necessarily because they are malicious. For example, weekends are rare days to send emails on, which is why our model attributes them such high scores despite containing no malicious emails.

We now examine our model’s ability to capture the

behaviour of our continuous features by comparing the observed summary statistics (Table 4) against the corresponding ensemble scores (Figure 4).

Table 4: Mean, median, and standard deviation of raw feature values for non-malicious and malicious emails, with size in kilobytes (KB) for ease of interpretation.

Feature	Group	Mean	Median	Std
Size (KB)	Non-mal.	390.76	31.93	992.13
	Mal.	1,181.79	809.78	1,460.25
# Attachments	Non-mal.	0.41	0.00	1.05
	Mal.	1.29	1.00	1.43
# Recipients	Non-mal.	2.32	2.00	1.35
	Mal.	1.38	1.00	1.87
Sem. Dev. (z)	Non-mal.	0.03	−0.07	1.02
	Mal.	1.13	1.35	1.09

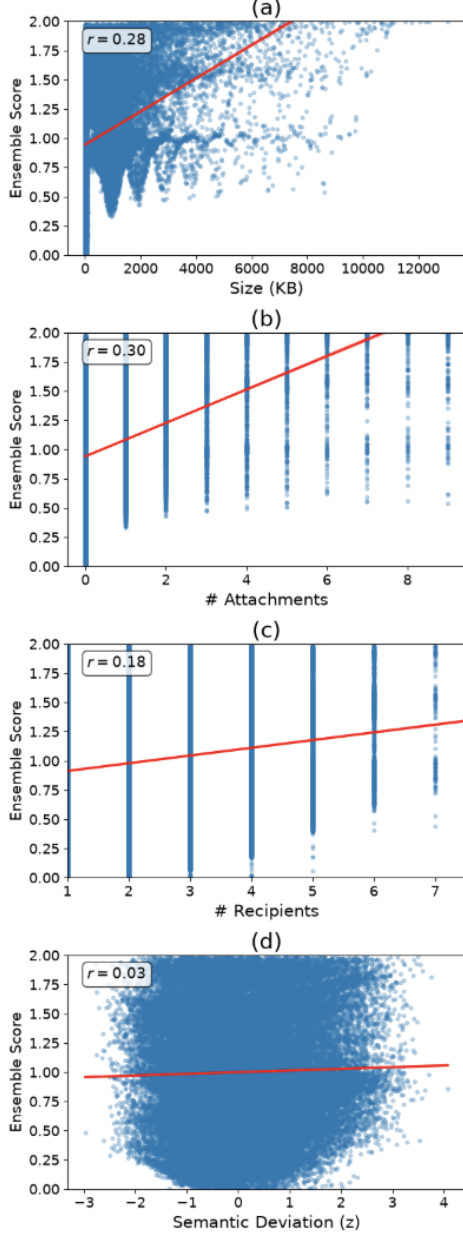


Figure 4: Ensemble score versus continuous feature values, with red fitted linear regression lines and Pearson correlation coefficients (r). (a) Size, (b) number of attachments, (c) number of recipients, (d) semantic deviation (z)

Firstly, malicious emails are larger and have more attachments on average, consistent with the moderate positive correlations between ensemble score and both size ($r = 0.28$) and attachment count ($r = 0.30$). Semantic deviation shows the largest gap between classes (means of 1.13 vs. 0.03) but near-zero correlation with ensemble score ($r = 0.03$). Recipient count is the one feature where the model’s direction disagrees with the data, where non-malicious emails average more recipients, yet score correlates positively with count ($r = 0.18$).

External sender, day-of-week, and recipient count

each show weak or inconsistent univariate signal, but these correlations only capture linear structure and exclude the collaborative value PCA and isolation forest can extract from their relationships with other features. We therefore retain all three and explore their value further in Section 3.2.3.

3.2.3 Feature Relationships and Importance

Because PCA is weighted most heavily in our ensemble and constructs its components from feature covariance, we examine the correlation structure directly (see Figure 5).

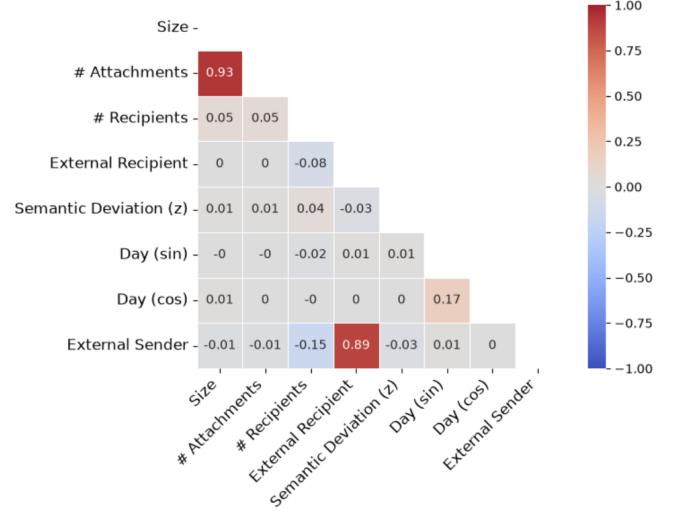


Figure 5: Pearson correlation matrix between features.

Size and attachment count are strongly correlated ($r = 0.93$), and so are external recipient and external sender ($r = 0.89$). In many modelling approaches this multicollinearity is an issue, as it inflates variance and confounds individual features’ contributions [11], however, we do not estimate per-feature coefficients, so this concern does not apply. We also note that semantic deviation and recipient count are largely uncorrelated with other features.

To assess our model’s reliance on individual features, we conduct permutation feature importance [12] on both PCA and isolation forest. To do so, each feature is shuffled 25 times and re-scored against the same fitted model, with the mean drop in recall at the 5% cut-off reported in Table 5.

Table 5: Permutation feature importance, measured as the mean drop in recall (%) at the 5% cut-off over 25 permutations, with standard deviation. Rankings of importance by model are provided in "Rank" columns. Values near zero indicate low reliance, with small negatives corresponding to sampling noise.

Feature	PCA			iF		
	Mean	Std	Rank	Mean	Std	Rank
External recipient	36.82	3.47	1	9.63	1.71	1
Size	35.71	1.96	2	3.55	2.58	5
# Attachments	34.20	1.81	3	-2.57	2.29	7
Day (cos)	31.84	3.83	4	-1.43	1.38	6
External sender	27.59	3.59	5	6.69	0.96	2
Day (sin)	20.41	5.44	6	-2.82	2.83	8
# Recipients	0.37	0.95	7	-1.39	1.63	4
Sem. Dev. (z)	-0.08	0.81	8	4.12	1.54	3

PCA relies most heavily on the correlated features, with external recipient, size, attachments, external sender, and both day encodings all producing recall drops above 20%, while semantic deviation and recipient count rank last, consistent with PCA’s method of drawing its components from covariance between features. However, we must note that permuting one feature from a correlated pair breaks a relationship present in the real data, so part of this drop reflects that broken structure rather than each feature’s independent contribution.

External recipient is the top feature for both models, indicating our detector treats messages leaving the organisation as the top signal of malicious behaviour. Semantic deviation contributes little to PCA but ranks third for isolation forest, showing isolation forest can flag semantically unusual emails without requiring covariation with other features. External sender ranks fifth for PCA and second for isolation forest, despite taking the same value for every malicious email. This likely reflects its interaction with external recipient, as permuting it breaks the relationship for PCA, while for isolation forest an internal sender paired with an external recipient is a rare combination the trees isolate in few splits.

3.2.4 Scenario Analysis

As mentioned in Section 2.1, our malicious emails are made up of three different scenarios, each defined in Appendix B. Table 6 breaks down recall by scenario.

Table 6: Recall (%) by malicious scenario at each anomaly-score cut-off, with the number of malicious emails in each scenario given as n .

Scenario	n	1%	5%	10%
1	13	0.00	23.08	69.23
2	15	0.00	13.33	20.00
3	70	50.00	72.86	98.57

Our model performs far better on scenario 3 (72.86% recall at 5%) than scenarios 1 or 2 (23.08%, 13.33%). Sce-

nario 3 is the only one where stolen data leaves the organisation by email rather than thumb drive, and it also accounts for $\approx 70\%$ of malicious emails, which is likely why external recipient emerged as the top feature in Section 3.2.3.

3.2.5 Score Separation and Evaluation Uncertainty

As a final investigation of our global ensemble model, we examine the separation it achieves between malicious and non-malicious emails (Figure 6), and the uncertainty around our recall estimates, quantified via 95% confidence intervals (Table 7).

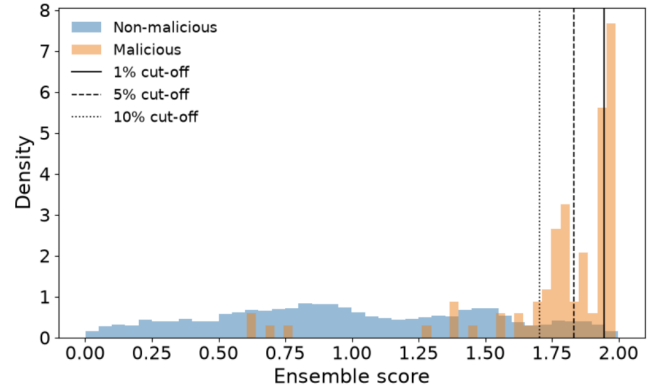


Figure 6: Histogram of ensemble scores for malicious and non-malicious emails. Malicious and non-malicious groups are each normalised to unit area for ease of comparison between email types, as malicious emails make up a small portion of the data. Vertical lines represent the top 1% (solid), 5% (dashed), and 10% (dotted) cut-offs.

As shown in Figure 6, with the exception of a few malicious emails scoring around 0.5–0.8, the ensemble separates malicious from non-malicious emails well, as malicious emails form a distinct cluster at the high end of the score range, while non-malicious emails are spread across the full range. The vertical lines mark our three cut-offs, letting us read the recalls of Table 2 directly. For example, at the 10% cut-off, the majority of malicious emails fall to the right of the threshold, corresponding to the recorded recall of 82.65%.

With only 98 malicious emails available, it is important to consider the uncertainty around our recall estimates. We therefore calculated 95% confidence intervals via bootstrap [13], resampling the malicious emails with replacement 2,000 times, recomputing recall within each resample, and taking the 2.5th and 97.5th percentiles of the resulting distribution. We hold the ranking of emails by ensemble score fixed, so our intervals reflect how much recall would vary if a different set of malicious emails had been observed, rather than how much it would vary if the model had been fitted differently.

Table 7: Recall (%) of the global ensemble model at each anomaly-score cut-off, with 95% confidence intervals generated via bootstrap.

Cut-off	Recall	95% CI
Top 1%	35.71	[26.53, 44.90]
Top 5%	57.14	[46.94, 66.33]
Top 10%	82.65	[74.49, 89.80]

As shown in Table 7, all three intervals span a relatively large range of roughly 15-19%, which is expected given the small number of malicious emails available. These recall values should therefore be read as rough estimates, useful for comparing models and exploring differences across scenarios and features, but not as exact measures of deployed performance.

4 Discussion

4.1 Limitations

While our global ensemble model improves upon simpler approaches, some limitations warrant consideration.

Firstly, we restrict each baseline to non-malicious emails. While this follows the standard semi-supervised approach, it remains a form of leakage, since the clean set is identified using the ground-truth answers file. The effect is likely modest, as malicious emails account for $\approx 0.6\%$ of all malicious users’ volume, so excluding them barely changes their baselines. However, refitting over each user’s full history would quantify this bias rather than assume it negligible.

Secondly, the computational cost of embedding email content restricted us to 50 non-malicious users alongside 13 malicious ones, from a population of 4,000, which is unlikely to capture the full diversity of legitimate email behaviour. We also have only 98 malicious emails, destabilising the cross-validation used to select ensemble weights and widening our recall confidence intervals. Repeating the analysis over a larger population would address this.

Thirdly, we compute semantic deviation by reducing each 384-dimensional embedding to a single cosine distance from the user’s centroid. This value separates malicious from non-malicious emails more clearly than any other feature, but contributes little to PCA, suggesting the reduction may discard structure the embeddings capture. Future work could score emails using all dimensions of the embedding rather than a single distance.

Lastly, 70 of our 98 malicious emails originate from a single scenario, biasing our results toward one attack type. Fitting separate models to each scenario may improve detection within each, while an even split across scenarios would give a better picture of overall performance.

4.2 Conclusion

The goal of this report was to detect malicious insider behaviour by representing each user’s email through both metadata and semantic content, and to assess the trade-offs between different historical baselines and anomaly-detection approaches.

We fitted four models across three baselines. Of these, the ensemble, which combines the scores of PCA reconstruction error and isolation forest, captured the highest in-sample proportion of malicious emails at every cut-off, well above the univariate z -score and random selection. Recall on users held out from weight selection was lower than in-sample recall, giving a more conservative but still positive indication of how well the model generalises to unseen users, remaining well above both the z -score and random selection. This suggests that models capturing the relationships between features outperform those scoring each feature independently, and that combining PCA’s use of covariance with isolation forest’s ability to represent normal behaviour in distinct regions produces a stronger detector than either alone.

No single baseline was best for every method. For example, the global baseline gave the highest recall for the z -score, isolation forest, and the ensemble, while the expanding baseline was strongest for PCA. The choice of baseline should therefore be treated as a modelling decision rather than fixed in advance. Our best results overall were under the global baseline, indicating that the stability gained from a larger baseline outweighs the per-user specificity lost by scoring against the whole organisation.

Examining the global ensemble model, we found PCA draws its signal largely from features that are strongly correlated with one another, aligning with how its components are constructed. Semantic deviation is largely independent of the other features and so contributed little to this model, but ranked third in importance for isolation forest, which can isolate a semantically unusual email without requiring covariation with other characteristics. Malicious emails also showed a clearly higher semantic deviation than non-malicious ones, so the feature is informative, even if PCA draws little on it.

For both methods, an email addressed outside the organisation was the most important feature. This aligns with our finding that the model performs best on scenario 3, the only scenario in which stolen data leaves the organisation by email.

We therefore recommend that an ensemble of models making use of the relationships between email characteristics, such as our combination of PCA reconstruction error and isolation forest, fitted under the global baseline, be used to detect malicious insiders who move data out of the organisation by email.

References

- [1] Joshua Glasser and Brian Lindauer. “Bridging the Gap: A Pragmatic Approach to Generating Insider Threat Data”. In: *2013 IEEE Security and Privacy Workshops*. IEEE, 2013.
- [2] Ivan Homoliak et al. “Insight Into Insiders and IT: A Survey of Insider Threat Taxonomies, Analysis, Modeling, and Countermeasures”. In: *ACM Computing Surveys* 52.2 (2019).
- [3] Brian Lindauer. *Insider Threat Test Dataset*. Carnegie Mellon University. https://kilthub.cmu.edu/articles/dataset/Insider_Threat_Test_Dataset/12841247. 2020.
- [4] Aaron Tuor et al. “Deep Learning for Unsupervised Insider Threat Detection in Structured Cybersecurity Data Streams”. In: *arXiv:1710.00811* (2017).
- [5] Varun Chandola, Arindam Banerjee, and Vipin Kumar. “Anomaly Detection: A Survey”. In: *ACM Computing Surveys* 41.3 (2009), pp. 1–58.
- [6] Nikolaos Passalis and Anastasios Tefas. “Learning bag-of-embedded-words representations for textual information retrieval”. In: *Pattern Recognition* 81 (2018), pp. 254–267.
- [7] Nils Reimers and Iryna Gurevych. “Sentence-BERT: Sentence embeddings using Siamese BERT-networks”. In: *Proceedings of the 2019 Conference on Empirical Methods in Natural Language Processing and the 9th International Joint Conference on Natural Language Processing (EMNLP-IJCNLP)*. Association for Computational Linguistics, 2019, pp. 3982–3992.
- [8] Mei-Ling Shyu et al. “A Novel Anomaly Detection Scheme Based on Principal Component Classifier”. In: *Proceedings of the ICDM Foundations and New Directions of Data Mining Workshop*. 2003, pp. 172–179.
- [9] I. T. Jolliffe. *Principal Component Analysis*. 2nd. Springer, 2002.
- [10] Fei Tony Liu, Kai Ming Ting, and Zhi-Hua Zhou. “Isolation Forest”. In: *2008 Eighth IEEE International Conference on Data Mining*. IEEE Computer Society, 2008.
- [11] John Neter, William Wasserman, and Michael H. Kutner. *Applied Linear Regression Models*. 4th. Richard D. Irwin, Inc., 1983.
- [12] André Altmann et al. “Permutation importance: a corrected feature importance measure”. In: *Bioinformatics* 26.10 (2010), pp. 1340–1347.
- [13] Tim Hesterberg. “Bootstrap”. In: *WIREs Computational Statistics* 3.6 (2011), pp. 497–526.

Appendices

A Dataset Variable Definitions

Table 8: Variables included in the dataset (pre-scoring)

Column	Feature	Description
Date	No	Email timestamp
User	No	Sender identifier
ID	No	Unique email identifier
Department	No	Sender’s department
Size	Yes	Email size (bytes)
Number of Attachments	Yes	Number of attachments
Number of Recipients	Yes	Number of recipients (To/Cc/Bcc)
External Recipient	Yes	Recipient outside organization (binary)
External Sender	Yes	Sender outside organization (binary)
Day (sin)	Yes	Sine of day-of-week encoding: $\sin\left(\frac{2\pi d}{7}\right)$, where $d \in \{0, 1, \dots, 6\}$
Day (cos)	Yes	Cosine of day-of-week encoding: $\cos\left(\frac{2\pi d}{7}\right)$, where $d \in \{0, 1, \dots, 6\}$
Semantic Deviation (z)	Yes	Standardised cosine distance embedding score (see Section 2.3)

B Insider Threat Scenarios

Table 9: Malicious insider scenarios present in the CERT r6.2 dataset [3], including only those that contain email events. Each scenario 1,2,3 corresponds to files r6.2-2, r6.2-3, r6.2-4, respectively.

Scenario	Description
1	User begins surfing job websites and soliciting employment from a competitor. Before leaving the company, they use a thumb drive (at markedly higher rates than their previous activity) to steal data.
2	System administrator becomes disgruntled. Downloads a keylogger and uses a thumb drive to transfer it to his supervisor’s machine. The next day, he uses the collected keylogs to log in as his supervisor and send out an alarming mass email, causing panic in the organization. He leaves the organization immediately.
3	A user logs into another user’s machine and searches for interesting files, emailing to their home email. This behavior occurs more and more frequently over a 3 month period.

C Baseline Tier Labels

Table 10: Baseline fallback tier definitions.

Tier	Definition
Personal	User’s prior emails
Department	Department’s prior emails
Global (window)	All users’ prior emails in last 30 days
Global (all prior)	All users’ prior emails
Missing features (NaN)	Email (or enough of the baseline pool) has a missing feature value
Insufficient data (NaN)	Fewer than the minimum baseline emails available at every tier

D Per-Fold Recall

Table 11: Per-fold held-out recall (%), evaluated at 1%, 5%, and 10% cut-offs. Each fold holds out two or three of the 13 malicious users.

Fold	1%	5%	10%
0	0.00	41.67	58.33
1	0.00	33.33	33.33
2	0.00	8.33	8.33
3	8.45	55.87	80.75
4	0.00	40.48	76.19
Mean	1.69	35.94	51.39
Std	3.78	17.46	30.44